

CYBERSECURITY FOUNDATIONS • WORKSHOP EXERCISE

From Findings to Action

Vulnerability Reporting & Security Communication

A Collaborative Workshop Applying Module 7 Lessons 1 & 2

Overview & Purpose

This afternoon, you will step into the role of a cybersecurity consultant serving as a Security Operations Center (SOC) analyst who has just completed a vulnerability scan for a fictional organization. Your job isn't just to find problems—it's to communicate them in a way that drives action.

This workshop combines two skill sets from this morning's lessons: **building a risk-informed vulnerability report** (Lesson 2) and **translating findings into audience-appropriate communication** (Lesson 1). In the real world, these two skills are inseparable - a perfectly prioritized report that nobody reads accomplishes nothing.

Learning Objectives Addressed

- Understand the goals and structure of an effective vulnerability report
- Identify key components that make reports actionable and relevant
- Apply risk-based prioritization techniques (severity + likelihood + business context)
- Use visuals to improve communication with technical and non-technical audiences
- Identify different stakeholder audiences and their communication needs
- Apply principles of timing, tone, and channel selection for effective messaging

Deliverables Checklist

By the end of the workshop, your team should have produced:

- Vulnerability Report (Executive Summary, Risk Rating table, Affected Assets, Remediation Recommendations, Supporting Details)
- One visual aid (a heatmap or dashboard sketch) supporting your report
- Executive / Leadership message (SITREP-style)
- Technical team alert
- End-user / general staff message (if applicable to your top finding)
- Short Leadership Briefing

Part 1: Build a Risk-Informed Vulnerability Report

Today's exercise covers two organizations. As a cybersecurity consultant, you have been tasked with providing services for the following company tracks: Track A (MedTech Solutions, a healthcare provider) and Track B (Summit Retail Co., a retail company). Turn to your track's data appendix at the end of this packet - it contains seven vulnerability scan findings for the respective organization.

Step 1 — Rank the Findings

Review all seven findings and assign each one a Priority Rank from 1 (most urgent) to 7 (least urgent). Do not rank by CVSS score alone - blend all three factors from Lesson 18:

- Severity (CVSS score) - how bad would exploitation be, technically?
- Likelihood - how probable is real-world exploitation, based on the context notes provided?
- Business context — is the asset public-facing? Is it mission-critical? What data does it touch?

REMEMBER

The highest CVSS score is not automatically the most urgent fix. A lower-severity finding on a public-facing, actively-targeted, business-critical system can outrank a higher-severity finding on an isolated, low-value system.

Step 2 — Write Your Executive Summary

Write a concise executive summary (3–6 sentences) that includes:

- Your top 3–5 critical findings, referenced by asset name (not just CVE ID)
- An overall risk posture statement (e.g., “2 critical, 3 high, 2 medium”)
- Immediate actions you recommend leadership approve

Step 3 — Complete the Risk Rating Table

Recreate the findings table in your own report, adding a Priority Rank column and a one-sentence justification for each ranking that references severity, likelihood, AND business context.

Step 4 — Detail Affected Assets & Remediation

For your top 3 priority findings, write a specific remediation recommendation (not just “patch it” — name the fix, a temporary mitigation if a full fix isn't immediately possible, and who should own the fix).

Step 5 — Add Supporting Details

List the CVE ID, a plausible scanner/discovery method (e.g., “identified via quarterly authenticated scan”), and note where a reference link would go for each of your top 3 findings.

Step 6 — Build a Visual Aid

Create ONE visual aid supporting your report - a heatmap (grid of systems vs. likelihood, color-coded by risk) or a dashboard sketch (open findings by severity, criticality breakdown). Hand-drawn, sketched on a whiteboard and photographed, or built digitally are all acceptable - the goal is showing you can translate the data into a glance-able visual.

Part 2: Translate Findings into Audience-Specific Communications

Using your top-priority finding as the basis, draft three separate messages. Apply everything from Lesson 1: audience needs, tone, timing, and channel.

Message 1 — Executive / Leadership Briefing (SITREP-style)

- Audience: executives and leadership
- Tone: calm, confident, business-risk-focused — avoid deep technical jargon
- Content: what's at risk, what you're doing about it, what decision (if any) you need from them
- Length: 3–5 sentences

Message 2 — Technical Team Alert

- Audience: your internal IT/security team
- Tone: direct, actionable, time-sensitive
- Content: CVE ID, affected asset, specific remediation step, deadline/urgency
- Length: 2–4 sentences or a short bulleted alert

Message 3 — End-User / General Staff Message

- Audience: non-technical staff (only draft this if your top finding affects something staff or customers would notice or need to act on)
- Tone: calm, clear, reassuring - no jargon
- Content: what's happening in plain language, what they should (or shouldn't) do, when to expect an update
- Length: 2-3 sentences

TIP

If your top-priority finding genuinely has no end-user angle (e.g., an internal-only system with no visible impact), write Message 3 for your second-priority finding instead, and note why you made that choice.

Part 3: Prepare Your Leadership Briefing

You will prepare a briefing as your organization's leadership team. Cover:

1. Your top 3 priority findings and why they ranked where they did.
2. Your visual aid - show it and explain what it reveals at a glance.
3. Your recommended immediate actions.
4. A live read of your Executive message and your Technical Team alert, so the class can hear the tone difference.

Submission Checklist

Before your briefing, confirm your team has:

- A written Vulnerability Report (Executive Summary, ranked Risk Rating table with justifications, Affected Assets & Remediation for top 3, Supporting Details)
- One visual aid (sketch or digital file)
- Three drafted messages (Executive, Technical, End-User)
- Prepared brief presentation

How You'll Be Evaluated

Your instructor will score your work across eight categories, worth 100 points total: Executive Summary, Risk Rating & Prioritization, Affected Assets & Remediation, Visual Aid, the three audience-specific messages, and your Presentation & Team Collaboration. Prioritization reasoning carries the most weight - showing your thinking matters more than reaching the exact same ranking as everyone else.

Appendix A — Track A Data Packet: MedTech Solutions

Track A: MedTech Solutions

MedTech Solutions is a regional healthcare provider offering an online patient portal, telehealth scheduling, and internal clinical support systems. A quarterly vulnerability scan has just returned the following seven findings. Your team has been asked to turn this into a report and communication plan for leadership.

CVE ID	Asset / System	CVSS	Exploit Likelihood	Exposure	Business Criticality
CVE-2024-1001	Patient Portal Web App (portal.medtechsolutions.com)	6.8	High	Public-facing	Critical (PHI)
CVE-2024-1002	Internal Analytics Reporting Server	9.6	Low	Internal only (isolated VLAN)	Medium
CVE-2024-1003	Remote Access VPN Gateway	8.1	High	Public-facing	Critical (all remote staff depend on it)
CVE-2024-1004	Employee Payroll System	5.4	Medium	Internal only	High (financial / PII data)
CVE-2024-1005	Legacy Fax-to-Email Gateway	7.2	Low	Internal only	Low (scheduled for decommission next quarter)
CVE-2024-1006	Guest Wi-Fi Captive Portal	4.3	Low	Public-facing	Low (no sensitive data accessible)
CVE-2024-1007	Appointment Scheduling API	6.1	High	Public-facing	High (integrates directly with Patient Portal)

Context Notes

- CVE-2024-1001 — A vendor advisory confirms this vulnerability class is being actively probed against healthcare portals this month.
- CVE-2024-1002 — No public exploit code exists; exploitation requires authenticated internal network access.
- CVE-2024-1003 — Named in this week's sector threat intelligence bulletin as actively targeted.
- CVE-2024-1004 — Exploitation requires local network access; no known active campaigns at this time.
- CVE-2024-1005 — Deprecated protocol rarely targeted; system is already being retired.
- CVE-2024-1006 — Limited to minor information disclosure only.
- CVE-2024-1007 — Proof-of-concept exploit code was published publicly five days ago.

Appendix B — Track B Data Packet: Summit Retail Co.

Track B: Summit Retail Co.

Summit Retail Co. operates an e-commerce storefront, in-store point-of-sale systems, and a customer loyalty program. A quarterly vulnerability scan has just returned the following seven findings. Your team has been asked to turn this into a report and communication plan for leadership.

CVE ID	Asset / System	CVSS	Exploit Likelihood	Exposure	Business Criticality
CVE-2024-2001	Online Checkout Service (checkout.summitretail.com)	7.4	High	Public-facing	Critical (PCI-DSS scope, card payments)
CVE-2024-2002	Corporate Intranet Wiki	9.4	Low	Internal only	Low
CVE-2024-2003	In-Store POS Terminal Firmware	8.3	High	Public-facing (customer-facing terminals)	Critical (PCI-DSS, card-present transactions)
CVE-2024-2004	Inventory Management API	5.9	Medium	Partner-facing (B2B integration)	High (supply chain data)
CVE-2024-2005	Marketing Email Platform (3rd-party integration)	6.5	Low	Internal / vendor-managed	Medium
CVE-2024-2006	Employee Time-Clock Kiosk	4.8	Low	Internal only	Low
CVE-2024-2007	Customer Loyalty Mobile App Backend	6.2	High	Public-facing	High (stores customer PII)

Context Notes

- CVE-2024-2001 — Actively exploited in the wild; flagged in this week's industry threat advisory.
- CVE-2024-2002 — Requires authenticated internal access; no public exploit code has been published.
- CVE-2024-2003 — Vendor advisory confirms active exploitation across multiple retailers this month.
- CVE-2024-2004 — Exploitation is possible but requires valid partner credentials.
- CVE-2024-2005 — No known exploit code has been published for this vulnerability.
- CVE-2024-2006 — Isolated to employee break rooms; no sensitive data involved.
- CVE-2024-2007 — Proof-of-concept exploit code was published on GitHub two days ago.